Matrice RBAC — Webapp Lidl Collect

> Ce document trace les droits de chaque rôle pour le rapport RGPD (Art. 30) et la documentation cybersécurité. Les droits sont implémentés dans le backend ce fichier en est la référence documentaire. 4 niveaux hiérarchiques : CLIENT < OPERATOR < MANAGER < ADMIN.

RÔLES ET PÉRIMÈTRE

RÔLE	ACTEUR	PÉRIMÈTRE DE DONNÉES
CLIENT	Utilisateur final	Ses propres données uniquement
OPERATOR	Préparateur	Commandes et stock de son magasin (storeId)
MANAGER	Manager de magasin	Opérateurs, planning et stock de son magasin (storeId)
ADMIN	Administrateur système	Tous les magasins, toutes les données

MATRICE DES DROITS PAR RESSOURCE

ACTION	CLIENT	OPERATOR	MANAGER	ADMIN
Profil				
Voir son propre profil	✅	✅	✅	✅
Modifier son propre profil (adresse, téléphone, email)	✅	✅	✅	✅
Voir le profil d'un autre utilisateur	❌	❌	❌	✅
Désactiver / supprimer un compte	❌	❌	❌	✅
Commandes				
Passer une commande	✅	❌	❌	✅
Voir ses propres commandes	✅	❌	❌	✅
Annuler sa propre commande	✅	❌	❌	✅
Voir les commandes du magasin	❌	✅	✅	✅
Modifier le statut d'une commande	❌	✅	✅	✅
Signaler une rupture de stock	❌	✅	✅	✅
Catalogue et produits				
Voir le catalogue	✅	✅	✅	✅
Modifier les produits / catégories / restrictions allergènes	❌	❌	❌	✅
Stock				
Voir le stock de son magasin	❌	✅	✅	✅
Modifier le stock de son magasin	❌	❌	✅	✅
Opérateurs et Planning				
Voir son propre planning	❌	✅	❌	✅
Voir les plannings des préparateurs de son magasin	❌	❌	✅	✅
Gérer le planning des opérateurs	❌	❌	✅	✅
Consulter la performance des opérateurs	❌	❌	✅	✅
Administration				
Accéder à l'interface admin	❌	❌	❌	✅
Gérer les magasins	❌	❌	❌	✅
Gérer les permissions	❌	❌	❌	✅
Voir les logs d'audit	❌	❌	❌	✅
Panier				

ACTION	CLIENT	OPERATOR	MANAGER	ADMIN
Créer / modifier son panier	✅	❌	❌	✅
Vider son panier	✅	❌	❌	✅
Voir les paniers abandonnés	❌	❌	❌	✅
Créneaux de retrait				
Voir les créneaux disponibles d'un magasin	✅	✅	✅	✅
Réserver un créneau (via commande)	✅	❌	❌	✅
Créer / gérer les créneaux de son magasin	❌	❌	✅	✅
Substitutions				
Proposer une substitution de produit	❌	✅	✅	✅
Accepter / refuser une substitution	✅	❌	❌	✅
Voir les substitutions d'une commande	✅	✅	✅	✅
Paiement *(table théorique — hors MVP)*				
Voir le statut de son paiement	✅	❌	❌	✅
Voir les paiements du magasin	❌	✅	✅	✅
Rembourser une commande	❌	❌	❌	✅
Fidélité				
Voir ses points fidélité	✅	❌	❌	✅
Modifier les points d'un client	❌	❌	❌	✅
Notifications				
Recevoir des notifications (confirmation, prête, substitution)	✅	❌	❌	❌
Déclencher une notification manuellement	❌	❌	❌	✅
Magasins				
Voir la liste des magasins disponibles	✅	✅	✅	✅
Droits RGPD				
Demander l'effacement de son compte (Art. 17)	✅	✅	✅	✅
Exporter ses données (Art. 20)	✅	✅	✅	✅
Rectifier ses données (Art. 16)	✅	✅	✅	✅

CONTRAINTE STOREID

OPERATOR et MANAGER ne peuvent accéder qu'aux données de **leur propre magasin**. La règle appliquée côté backend :

```
role == OPERATOR  →  user.storeId === resource.storeId
role == MANAGER   →  user.storeId === resource.storeId
```

Un OPERATOR ou MANAGER qui tente d'accéder à un autre magasin doit recevoir une erreur `403 Forbidden`.

DONNÉES ACCESSIBLES PAR RÔLE (VUE RGPD)

DONNÉE PERSONNELLE	CLIENT	OPERATOR	MANAGER	ADMIN
Nom / prénom client	Les siens	❌	❌	✅
Email client	Le sien	❌	❌	✅
Téléphone client	Le sien	❌	❌	✅
Adresse client	La sienne	❌	❌	✅
Géolocalisation	Non stockée (à la volée uniquement)	—	—	—
Statut du compte (is_verified, is_active)	Le sien	❌	❌	✅
Date de création / dernière connexion	Les siennes	❌	❌	✅
Historique commandes	Les siennes	Son magasin	Son magasin	✅
Paniers abandonnés	❌	❌	❌	✅
Créneaux réservés	Les siens	Son magasin	Son magasin	✅
Points fidélité	Les siens	❌	❌	✅
Données pro Préparateur	❌	Les siennes	Son magasin	✅
Données pro Manager	❌	❌	Les siennes	✅
Performance Préparateur	❌	Les siennes	Son magasin	✅
Planning (Schedule)	❌	Le sien	Son magasin	✅
Notifications reçues	Les siennes	❌	❌	✅
Consentements enregistrés	Les siens	❌	❌	✅
Mot de passe hashé	Jamais exposé	Jamais exposé	Jamais exposé	Jamais exposé
Adresse IP (AuditLog)	❌	❌	❌	✅
Logs d'audit	❌	❌	❌	✅
Tokens JWT	Non stockés (expiration automatique)	—	—	—
Consentements cookies	Les siens	❌	❌	✅

CONFIGURATION JWT — RÉFÉRENCE POUR DORIAN (NESTJS)

> Source : politique d'authentification Willy. Ces valeurs doivent être imposées côté backend (non négociables)

Durées de session par rôle

RÔLE	ACCESS TOKEN	REFRESH TOKEN
CLIENT	15 minutes	7 jours
OPERATOR	15 minutes	8 heures
MANAGER	15 minutes	8 heures
ADMIN	10 minutes	4 heures

Contraintes de configuration

- **Algorithme imposé :** HS256
- **Rejet de** `alg: none` **obligatoire** à configurer explicitement dans le guard JWT
- **Reponse minimal :** `userId`, `role`, `storeId` aucune donnée personnelle dans le token
- **MFA obligatoire** pour OPERATOR, MANAGER, ADMIN géré par Willy, à coordonner avec Dorian

VECTEURS D'ESCALADE DE PRIVILÈGES — À PROTÉGER

VECTEUR	DESCRIPTION	MESURE À IMPLÉMENTER
IDOR (Insecure Direct Object Reference)	Un CLIENT accède à `/orders/42` appartenant à un autre client	Vérifier `order.clientId === req.user.id` côté backend
Payload JWT modifiable	Le champ `role` est modifié côté client avant envoi	Le rôle doit être lu en base à chaque requête, pas uniquement depuis le token
Endpoint admin non protégé	Un OPERATOR appelle `/admin/*` sans guard actif	Guard `RolesGuard` obligatoire sur toutes les routes admin
Violation storeId	Un OPERATOR accède aux commandes d'un autre magasin	Guard `StoreOwnershipGuard` : `user.storeId === resource.storeId`
`alg: none` JWT	Token forgé sans signature accepté par le serveur	Rejeter explicitement `alg: none` dans la config JWT NestJS

SCÉNARIOS DE TEST — À VALIDER AVANT LIVRAISON

Ces tests doivent passer avant que la matrice soit considérée comme implémentée.

#	SCÉNARIO	RÉSULTAT ATTENDU
1	CLIENT fait `GET /admin/orders`	`403 Forbidden`
2	OPERATOR fait `GET /stores/:autreStore/orders` (storeId différent)	`403 Forbidden`
3	CLIENT fait `GET /orders/:idAutreClient`	`403 Forbidden`
4	OPERATOR fait `DELETE /users/:id`	`403 Forbidden`
5	Token avec `alg: none` envoyé sur n'importe quel endpoint protégé	`401 Unauthorized`